

Big Desks and Little People

Daniel Hardman

2023-05-01

Abstract

This article discusses the power imbalance in digital trust architectures, advocating for designs that empower individuals over institutions.

We are not paying enough attention to how our designs for high-trust interactions limit the autonomy of individuals. Familiar architectural patterns such as client-server APIs and business process workflows are useful, but they can empower orgs at the expense of people. Perhaps we can still use such building blocks, but we need to understand their risk and think about them differently.

A Neglected Risk

All of us know that trust is broken on the internet because of problems with authenticity, confidentiality, and privacy (ACP). [1, 2, 3, 4, 5, 6] Six hyperlinks barely scratch the surface, and AI's ability to generate fake everything is only going to make all of it worse... These problems are deep and scary, and I'm glad people are working on them. #esc #efa

But if our summary of the problem ends with ACP, we're still neglecting something crucial. Trust is also broken because of a pervasive, asymmetrical interaction pattern that I call "big desks and little people." We are addicted to infrastructure that systematizes and normalizes a power imbalance between institutions and individuals. This addiction creates ideal conditions for abuse, and it interacts with ACP issues (and AI, BTW) in a vicious cycle.

Big desks and little Thomas More in A Man For All Seasons (1966). Fair use.

Power Corrupts...

The "big desks and little people" problem is old, old, old. A familiar historical example comes from the life of Sir Thomas More, a British statesman. On July 1, 1535, he stood alone before empaneled judges and jury, charged with treason, and pled for his life.

More was loyal to King Henry VIII and had served him faithfully for years. However, he remained silent when asked to publicly endorse a new law that legitimized the king's wedding to Anne Boleyn. This offended the crown. Evidence that More had done anything treasonous was dubious at best. More, a superb lawyer, made strong legal arguments. However, the king had decreed what the verdict must be, and *he owned the big desks*. His jury included the king's new chancellor and three relatives of the queen. Little Thomas More was convicted after only fifteen minutes of deliberation, and he was beheaded five days later.

Trust could not survive *big desks and little people*.

Abuse follows...

The defining characteristic of this antipattern is that one party embodies an org backed by impressive infrastructure, and the other party is a person with many constraints and limited power — and this imbalance leads them to play by different rules. When this happens, obnoxious effects follow, and these effects undermine trust, *even if we solve pretty well for authenticity, confidentiality, and privacy. ACP can (and will) be exploited, given enough distortion in power.* (For a deep exploration of such harms, see ToIP’s whitepaper.)

George Orwell warned about this.

The fundamental offense of the pigs in *Animal Farm* was not that they betrayed the trust of their fellow farm animals by issuing fake edicts (authenticity), or by exposing secrets (confidentiality), or by monitoring what the animals said (privacy). Those dimensions of trust started out healthy. It was that the pig cabal took advantage of a power differential to play by different rules from individual citizens. This trend was hard to detect at first, but eventually it became obvious; they replaced their seven idealistic standards (including the last, “All animals are equal”) with a single new commandment: “ALL ANIMALS ARE EQUAL BUT SOME ANIMALS ARE MORE EQUAL THAN OTHERS” (all caps in original). By then it was game over for trust.

Something deep in our psyche knows that this risk can bite us. We reference it in some of our most resonant mythologies:

Big Mr. Potter’s desk, little George Bailey in *It’s a Wonderful Life* (1946). Fair use.

A goblin intimidating Harry from behind a big desk at Gringotts. Fair use.

The pathos in these imaginary situations comes *not from their fiction, but from their truth*; More’s unhappy ending tells us that.

Psychologists have noted the effects of this power dynamic in many contexts. Mark Zuckerberg was concerned enough about big desks and little people that he sat on a booster cushion as he testified before the US congress. The maxim “Power tends to corrupt and absolute power corrupts absolutely” comes from Lord Acton, a historian, and he distilled it as a truism about persecution of minorities throughout history...

Big desks and little people in tech

Can you think of any examples where orgs and people play by different rules *in tech*?

I see many. We authenticate orgs with certs but individuals with passwords; orgs fill the digital landscape with Hobson’s choices for people, but none for themselves; we assume that digital credentials are held by people with the goal of making issuers and verifiers happy; we are content to let internet giants train all the big AIs that everybody’s so excited about (using data from little people, for free), and then direct all legal blame for misusing them toward little people...

Here, though, I’d like to focus on something far subtler and far more pervasive. It’s a source of obvious utility, but also of risk that we hardly acknowledge at all, which makes it all the more dangerous:

client-server architecture

Client-server is THE architectural pattern that defines the web; browsers and mobile devices are clients, and web sites and web APIs are servers. You're reading this post because your client software asked a server to send it to you. Client-server powers secure communications technologies like Signal and WhatsApp. Client-server is behind Alexa and Siri. It's at the heart of enterprise service buses and business process automation. It's the lifeblood of e-commerce. It's the dominant design pattern for most CBDCs that are being touted as upgrades to the world's financial system. It's how chatGPT services the public. Client-server is also the paradigm that informs W3C's VC API, DWNs, and OIDC4VC.

And I'm saying it's dangerous in a *big desks and little people* way, when we use it *in conjunction with individual identity*.

Yep.

The case for danger, part 1

Pick any of the technologies I just listed as examples of client-server architecture, and ponder the following questions:

- Which direction do terms and conditions always flow, in a client-server approach?
- Who gets to report errors? (HTTP makes this question very stark. HTTP only reports errors in HTTP responses — which always come from the server. And consider the inventory of possible HTTP errors. Web servers don't report problems on their side in detail; the set of common 5xx errors is small, and usually degenerates into 500/503. Meanwhile, web servers have a rich catalog of ways to blame the client.)
- Whose view of interaction state is considered authoritative?
- Who defines the interface for these interactions?

I claim that thoughtful answers to these questions expose important, systemic, troubling power imbalances, because they don't fit well with the free and empowered management of identity by individuals. What did Lord Acton claim about power imbalances?

A simple desultory philippic

This may feel like a digression, but I promise it connects.

I am a US citizen living in Switzerland. Filing taxes for two countries is a big headache.

In 2022 I used a big-5 accounting firm to do my taxes, and I had a horrible experience. The Swiss deadline was March 15, and the US deadline was April 15. I submitted everything in February. March came and went, and I heard nothing. I sent a nag email requesting status. No response. I tried again, and got a message back: "Oh, don't worry about deadlines. We filed an extension request on your behalf."

Since I had provided my paperwork on time, and had NOT asked them to file an extension request, I was quite irritated. I was trying to do some financial planning, and I really needed to know, ASAP, the nature of my tax bill. This org had given themselves an extension without consulting me at all. Since when was that a benefit to me, and since when did they get to pick the deadlines?

I waited a while, then nagged again. More time went by.

Eventually I got another email: “Congrats, your taxes are all done. Here’s how you can pay your late fees totaling over 1000 USD.”

I complained bitterly. They had never warned me that their decision to file an extension might entail late fees; in fact, they had made it sound like such a routine thing that I was lulled into a false sense of security about it. But even if I had been alarmed, they had not sought my approval in the first place. They had communicated poorly, ignored my escalations, and cost me lots of money with no justification other than their own backlog.

My complaints went up the corporate ladder at the accounting firm. Eventually a mid-level manager approved a special dispensation to reimburse me for half of my fees, and I was informed that they had closed the case. I paid the penalties myself, and saw the partial reimbursement months later.

Fast forward to 2023. In February I got an email from this firm, inviting me to submit tax data for the next iteration of taxes. I wrote them a brief response saying that I was still angry about last year’s experience, and didn’t intend to be their client anymore.

But I kept getting nagged anyway. Here is an actual screenshot from their 10th nag message about this:

Notice the red marks. *Remember my question about which direction terms and conditions always flow?*

Consider the fact that I had already contacted them to cancel the relationship, and they weren’t listening. Remember my question about who gets to report errors?

While I was being nagged, I attempted to do my own Swiss taxes, but couldn’t find a crucial paper that the government had supposedly mailed me. Only after I contacted a Swiss official by phone did I learn that this paper had been mailed to the problematic accounting firm, who never bothered to tell me about it. *Remember my question about whose view of the relationship is considered authoritative?*

Notice the yellow marks. They imposed a deadline on me (almost a month beyond the Swiss deadline, and with no explanation, BTW). Does this seem reasonable, given the lack of urgency I experienced from them? *Remember my question about who defines the interface for the interaction?*

Now, I am certain that nobody intended any evil here. I blurred out the name of the company in the screenshot because I intend no public shaming. The employees of this company seem like well-meaning people. However, I think the situation illustrates what happens when the *big desks and little people* pattern characterizes an interaction on today’s tech landscape: *trust is undermined, and little people suffer.*

But is this a story about client-server — or is it just a story about unreasonable customer service? *That is a distinction without a difference, because they look the same from the perspective of a disempowered client.* All of my interactions with the company took place through technical client-server interfaces (email, a portal, a Zoom meeting), and AI may quickly be able to supply every behavior I observed from this company. Maybe that will give great benefits to big desks. However, I see no reason to believe in an upside for the little guy — not when we force them to interact the same way they’ve always done. *The reason client-server and client-customer-service look the same is because both give the client the same options and lead to the same trust profile.*

Helping people manage their data does not empower them, if we require them to contract with

a big desk to do it. Giving DIDs and credentials to vulnerable people does not empower them, if we only standardize their use to satisfy orgs behind big desks. An identity world built on client-server assumptions is a far cry from the empowered, safe, self-sovereign values that we claim we're promoting. Shouldn't we be worried about THAT if we want to fix trust?

Some people who read this will say, "Aha! This is why we need governance frameworks!" To which I would say, "Yes, those are vital. But we design governance for risks we *recognize*. How many governance frameworks have you seen that contemplate the risks I'm highlighting here? And is a new layer of corrective policy the best way to drive risk out of the system, or should we fix it by changing how we use the tech in the first place?"

The case for danger, part 2

My list of thought questions above was just a beginning. Here are some other points to ponder regarding power dynamics in client-server architectures. Many might be worthy of a separate essay:

- How does Conway's Law manifest with client-server, and why does this virtually guarantee *big desks and little people*?
- Which role — clients or servers — has lawyers and accountants and lobbyists de-risking the interaction for them?
- Who funds the standards-making bodies for most client-server interfaces, and who therefore blesses their requirements?
- Servers are automated; clients might not be. This often leads to prioritizing different kinds of trust, for different reasons. Does this differentiation reflect a deep truth about orgs and humans, or does it just invite sloppy thinking?
- Servers and clients are usually built by different engineers. How does this affect power dynamics?
- Why do both Wikipedia and Encyclopedia Britannica note a connection between client-server and centralization?
- An OpenAPI (Swagger) API carefully documents what a client must do, and how a server might respond in the abstract. Why is it typical for documentation to neglect the order of the steps, their preconditions and postconditions, the server's duties toward web hooks, and what the server does between the steps?
- How does client-server drive temporal coupling? (Who has to be connected, when and where, to make it work — and how does this influence implementation?)
- Where is computational horsepower in a client-server architecture, and how does this influence the maturing of automation and sophisticated policy?
- Who decides when an interface will be updated or deprecated?
- How does an asymmetric interaction pattern determine the economics of hacking? How about scaling?
- Who keeps the records?
- Why does client-server have a strong affinity for data-centric worldviews, and is it safe to model humans mostly as data sources?

The list is still not exhaustive, but I'll stop there.

What to do?

I am not on a crusade to eliminate client-server architectures. They are useful. I've built many myself, and I'll no doubt build more. For lots of problems, they're a great solution.

Rather, I want to raise a warning. *When we use client-server to manage the identity of a vulnerable client that needs advocates, we are not paying enough attention to the risks of big desks and little people.* We seem to be fixated on ACP and on credentials, and we are WAY too comfortable with infrastructure that is asymmetric. We don't only need ACP, though we certainly need that; we also need to change our interaction patterns.

Standardizing credential exchange as a client-server interaction marginalizes people as mere holders, and makes big desks bigger. Standardizing how people log in to orgs while ignoring how orgs log in to people marginalizes people and makes big desks bigger. Thinking of secure communication or data sharing interactions as a client-server problem, with heavy lifting taking place between beefy nodes rented from big orgs, marginalizes people and makes big desks bigger.

Although we definitely want trusted interactions with orgs, we shouldn't need to be little people clients of big desk servers every time we want a trusted and interoperable digital interaction.

Building infrastructure that imposes this requirement may not be evil, but it's risky, in exactly the way that More and Orwell and Acton warn about. If we continue on our current trajectory, I worry that we'll have authentic, confidential, and private interactions — but only with or through orgs that bully and marginalize and exploit us.

That might be a world where orgs can trust people, but it's not one where people can trust orgs. It doesn't fix our broken internet.